

Examples of Passive and Active Reconnaissance

Estimated time needed: 5 minutes

Learning objectives

- Describe the concept of reconnaissance in cybersecurity
- Explain the differences between passive and active reconnaissance
- Identify techniques used in passive and active reconnaissance
- Illustrate examples of how attackers use different reconnaissance techniques

Overview of reconnaissance

Reconnaissance is the process of gathering information about a target network or system to identify potential vulnerabilities. In this reading, you will learn about the types of reconnaissance and how passive and active reconnaissance techniques are used to gather information about target systems in cybersecurity.

Defenders must prepare for security measures and attackers to plan an intrusion. Based on the technique used to gather information, reconnaissance is categorized as passive or active.

Passive reconnaissance

Passive reconnaissance involves stealthily gathering information about a target system or network without any direct interactions between the attackers and the target. It enables attackers to exploit unsecured, publicly available information to create target profiles without raising alarms. Here are examples of passive reconnaissance techniques:

- **Websites** provide attackers with information on organizational structure and technologies and alert them to potential weak spots. For example, attackers can exploit outdated content management systems (CMS) on company websites and use unpatched vulnerabilities to access internal databases.
- **Domain registrations** equip attackers with extensive information on the domain owner. This information can be used to launch phishing or impersonation attacks. For instance, an attacker can find the personal contact details of domain owners and send phishing emails to steal their login credentials.
- **Social media** enables quick and easy access to data on employee roles, company culture, and other public information. Attackers can potentially use this information to plan targeted attacks. For example, an attacker may identify a company's leadership personnel on LinkedIn and send them personalized phishing emails to trick them into revealing sensitive data.
- **Public records**, such as business filings or legal documents, can give attackers insights into a company's operations and key personnel. They can use this information to plan targeted attacks. For example, attackers can gather details about company executives from public filings, such as government databases, and launch a spear-phishing campaign against them.
- **Job postings** often reveal information on the technologies and systems used by the company that attackers can exploit if there are known vulnerabilities. For instance, an attacker might see that a company was using specific software from a job posting and use a known vulnerability in that software to attack.
- **Online forums and communities** provide a portal to extensive insider information and industry trends on online forums. Attackers might use this knowledge to exploit known issues or for social engineering. For example, an attacker can find details on an organization's recent security problems on a forum and leverage it to create a targeted phishing attack.

Active reconnaissance

Active reconnaissance involves direct engagement with a target system or network to gather detailed information, which can help in planning attacks. Unlike passive reconnaissance, it requires direct interaction with the target, which can trigger alerts. Here are examples of active reconnaissance techniques:

- **Network mapping tools** help discover live hosts, open ports, and public services, creating a detailed map of the network infrastructure. Attackers can use this map to identify vulnerable points within the network. For example, an attacker might use a network mapper to find an open port running outdated software, which they can then exploit to gain unauthorized access.
- **Ping sweeps and traceroutes** uncover potential security gaps and entry points for attacks. Attackers use ping sweeps to identify active hosts and traceroutes to map the network layout by revealing the data paths and network topology. For instance, an attacker might perform these scans to discover the network's structure and pinpoint weak areas to target with specific attacks.
- **Banner grabbing** captures information about the services and software versions running on a server. Attackers use banner grabbing to identify specific software vulnerabilities. For example, an attacker might use banner grabbing to determine the server's software version and exploit a known vulnerability associated with that version.
- **Packet sniffing tools**, like Wireshark, capture and analyze unencrypted network traffic, allowing attackers to extract sensitive information such as login credentials. This data can be used to hijack sessions or access secure systems. For instance, an attacker might capture network traffic to obtain login information, which they could then use to change credentials or gain unauthorized access to the system.
- **Vulnerability scanning tools** like Nessus and Open Vulnerability Assessment System (OpenVAS) identify and assess known vulnerabilities in hosts and services. Attackers may exploit these vulnerabilities to gain unauthorized access or disrupt services. For example, a vulnerability scanner might reveal an unpatched flaw on a server, which the attacker could then exploit to breach the system.
- **Domain name system (DNS) enumeration** involves discovering domain names, internet protocol (IP) addresses, DNS records, and subdomains associated with a target. Attackers use DNS enumeration to uncover hidden subdomains that could be targeted for attacks. For example, an attacker might find a hidden subdomain through DNS enumeration and target it with a DNS spoofing attack.
- **Social engineering** includes manipulating individuals to extract sensitive information or gain access to systems. Attackers exploit human psychology rather than technical vulnerabilities. For example, an attacker might pose as an information technology (IT) technician and trick an employee into revealing their login credentials over the phone, allowing the attacker to access secure network parts.

- **Dumpster diving** is the process of searching through discarded documents and other physical waste to find valuable information. Attackers can use this information to plan and execute targeted attacks. For instance, an attacker might retrieve sensitive documents from a company's trash and use the information to launch a targeted attack against the organization.

Summary

In this reading, you learned how passive and active reconnaissance techniques are used to gather information about target systems in cybersecurity.

- Passive reconnaissance involves stealthily collecting data from publicly available sources to identify potential vulnerabilities without direct interaction.
- It includes gathering information from websites, social media, domain registrations, public records, job postings, and online forums without directly interacting with the target.
- Active reconnaissance requires direct engagement with the target to uncover weak points and help plan attacks.
- It includes network mapping, ping sweeps, traceroutes, banner grabbing, packet sniffing, vulnerability scanning, DNS enumeration, social engineering, and dumpster diving.

Author(s)

Dee Dee Colette



Skills Network